

# Play Threat Profile

---

Date: February 26, 2026

**Play** (also known as **PlayCrypt**) is a highly sophisticated cybercriminal group specializing in ransomware. Since emerging in June 2022, the group has gained a reputation for its "Big Game Hunting" tactics, targeting large enterprises and government entities across the globe.

Here is a detailed breakdown of the group's profile, tactics, and characteristics:

## 1. Origins and Evolution

The group is named after the **.play** file extension it appends to encrypted files and the word "Play" contained within its ransom notes. While their specific location is unknown, their tactics and timing suggest a Russian-speaking or Eastern European origin, a common trait among top-tier ransomware gangs.

Unlike many of its competitors (like LockBit or ALPHV/BlackCat), Play is believed to operate as a **closed group** rather than a traditional Ransomware-as-a-Service (RaaS) model. This means they likely handle their own intrusions and negotiations rather than recruiting a wide network of affiliates.

## 2. Tactics, Techniques, and Procedures (TTPs)

Play is known for technical innovation and the use of "living-off-the-land" (LotL) techniques—using a system's own legitimate tools to carry out an attack.

- **Initial Access:** They frequently exploit known vulnerabilities in unpatched software. Most notably, they pioneered the "**OWASSRF**" exploit (a bypass of Microsoft Exchange's ProxyNotShell mitigations) to gain access to corporate networks. They also use compromised VPN credentials and RDP (Remote Desktop Protocol) exploits.
- **Discovery and Lateral Movement:** Once inside, they use tools like **Cobalt Strike**, **AdFind**, and **Mimikatz** to escalate privileges and move through the network.
- **Data Exfiltration:** Before encrypting any files, they steal sensitive data using tools like **WinSCP** and **Rclone**. This allows them to perform **Double Extortion**: demanding payment for the decryption key and a separate payment to prevent the public leaking of stolen data.

## 3. Technical Signature: Intermittent Encryption

One of Play's most distinctive technical features is **intermittent encryption**. Instead of encrypting an entire file, the ransomware encrypts only chunks of the data (e.g., every 10 MB).

- **Why?** This makes the encryption process significantly faster and allows the malware to bypass some security software that looks for the heavy CPU usage and high-frequency file I/O associated with full encryption.

## 4. Communication and Ransom Notes

Play's ransom notes are famously minimalist. While most groups leave long instructions, Play typically leaves a simple text file named **ReadMe.txt** containing only the word "PLAY" and a contact email address.

- They host a "Wall of Shame" on the Tor network (the Dark Web) where they list victims who refuse to pay and leak their data in stages to increase pressure.

## 5. Notable Targets

Play does not appear to have a specific industry bias, but they target organizations with high-value data and low tolerance for downtime. Notable victims include:

- **The City of Oakland:** A 2023 attack that disrupted municipal services for weeks.
- **Rackspace:** A high-profile attack on the cloud service provider's hosted Exchange environment in late 2022.
- **H-Hotels:** A major European hotel chain.
- Various global entities in the legal, financial, and manufacturing sectors.

## 6. Connections to Other Groups

Security researchers have noted similarities between Play's code and the ransomware used by the **Hive** and **Nokoyawa** groups. While this doesn't necessarily mean they are the same people, it suggests they may share developers or source code in the tight-knit cybercrime underground.

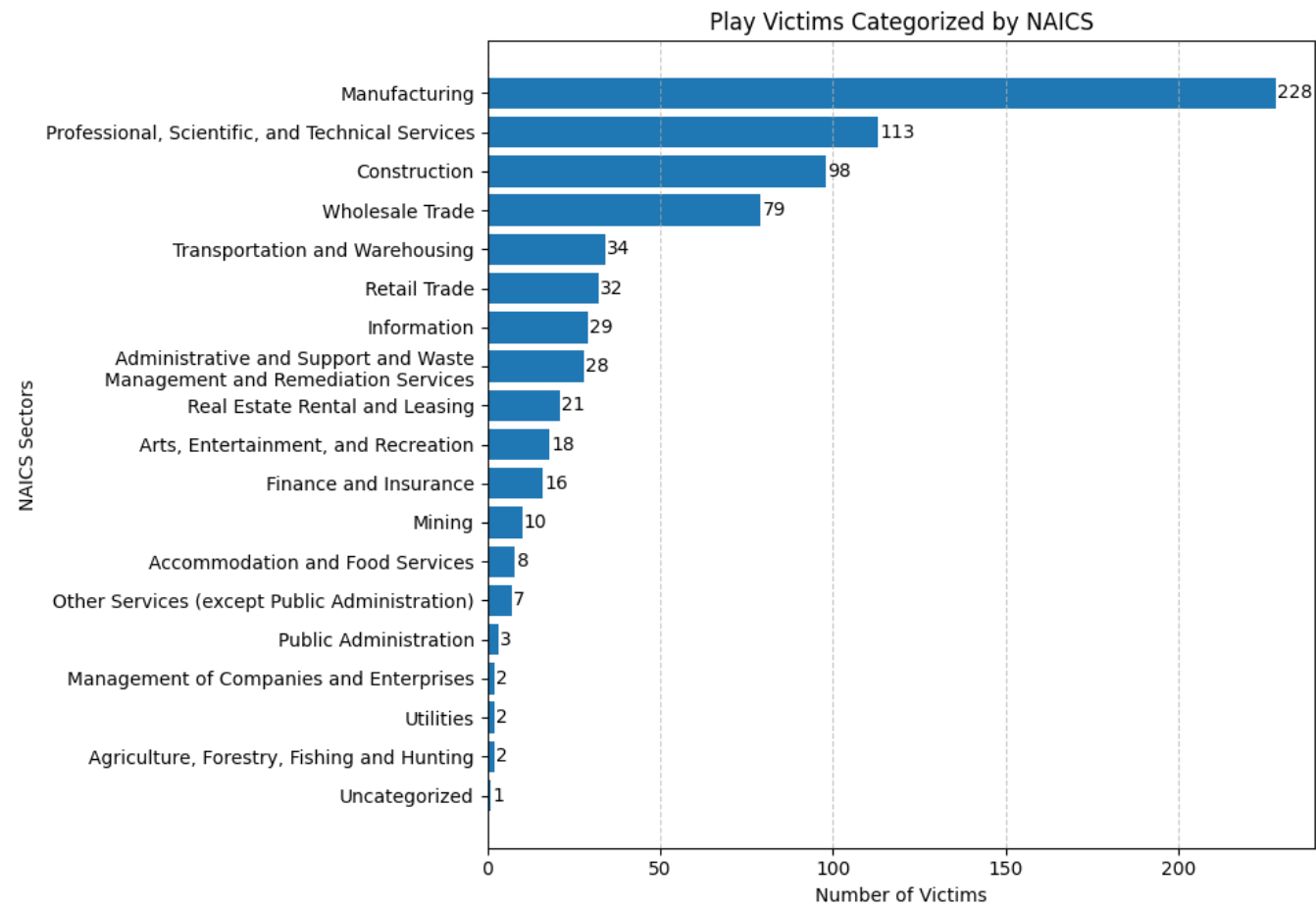
## Summary of Risk

The Play ransomware group is considered a **high-tier threat** because:

1. They develop their own custom exploits (like OWASSRF).
2. They work quickly, often moving from initial access to full encryption in a matter of days.
3. Their "closed" nature makes them harder for law enforcement to infiltrate compared to affiliate-based groups.

**Defensive Recommendation:** Organizations are advised to prioritize patching Microsoft Exchange vulnerabilities, enforce Multi-Factor Authentication (MFA) on all VPNs/RDPs, and employ behavioral-based EDR (Endpoint Detection and Response) to catch their intermittent encryption patterns.

Industry Targeting



Malware

| Name |               |
|------|---------------|
| 0    | Coroxy        |
| 1    | ransomware    |
| 2    | Grixba        |
| 3    | SystemBC      |
| 4    | Cobalt Strike |
| 5    | Playcrypt     |

Indicators Valid Until March 23, 2026 12:42 AM UTC

| Type | Name    |                                                                  |
|------|---------|------------------------------------------------------------------|
| 0    | SHA-256 | 75404543de25513b376f097ceb383e8efb9c9b95da8945fd4aa37c7b2f226212 |
| 1    | SHA-256 | 75b525b220169f07aecfb3b1991702fbd9a1e170caf0040d1fcb07c3e819f54a |
| 2    | SHA-256 | c59f3c8d61d940b56436c14bc148c1fe98862921b8f7bad97fbc96b31d71193c |
| 3    | SHA-256 | 7a42f96599df8090cf89d6e3ce4316d24c6c00e499c8557a2e09d61c00c11986 |

|   | Type    | Name                                                             |
|---|---------|------------------------------------------------------------------|
| 4 | SHA-256 | 453257c3494addafb39cb6815862403e827947a1e7737eb8168cd10522465deb |
| 5 | SHA-256 | 7dea671be77a2ca5772b86cf8831b02bff0567bce6a3ae023825aa40354f8aca |
| 6 | SHA-256 | 0e408aed1acf902a9f97abf71cf0dd354024109c5d52a79054c421be35d93549 |
| 7 | SHA-256 | 47b7b2dd88959cd7224a5542ae8d5bce928bfc986bf0d0321532a7515c244a1e |

## Attack Patterns

|    | Name                                    | MITRE ID                  |
|----|-----------------------------------------|---------------------------|
| 0  | Command Obfuscation                     | <a href="#">T1027.010</a> |
| 1  | Malicious File                          | <a href="#">T1204.002</a> |
| 2  | Dynamic Resolution                      | <a href="#">T1568</a>     |
| 3  | Domain or Tenant Policy Modification    | <a href="#">T1484</a>     |
| 4  | Defacement                              | <a href="#">T1491</a>     |
| 5  | System Network Connections Discovery    | <a href="#">T1049</a>     |
| 6  | Create or Modify System Process         | <a href="#">T1543</a>     |
| 7  | SMB/Windows Admin Shares                | <a href="#">T1021.002</a> |
| 8  | Software Packing                        | <a href="#">T1027.002</a> |
| 9  | Account Access Removal                  | <a href="#">T1531</a>     |
| 10 | Deobfuscate/Decode Files or Information | <a href="#">T1140</a>     |
| 11 | Software Discovery                      | <a href="#">T1518</a>     |
| 12 | Remote Services                         | <a href="#">T1021</a>     |
| 13 | T1009                                   | <a href="#">T1009</a>     |
| 14 | Server Software Component               | <a href="#">T1505</a>     |
| 15 | Domain Generation Algorithms            | <a href="#">T1568.002</a> |
| 16 | Windows Command Shell                   | <a href="#">T1059.003</a> |
| 17 | User Execution                          | <a href="#">T1204</a>     |
| 18 | Exfiltration Over C2 Channel            | <a href="#">T1041</a>     |
| 19 | Domain Accounts                         | <a href="#">T1078.002</a> |
| 20 | Financial Theft                         | <a href="#">T1657</a>     |
| 21 | Unix Shell                              | <a href="#">T1059.004</a> |
| 22 | LSASS Memory                            | <a href="#">T1003.001</a> |

|    | Name                                   | MITRE ID                  |
|----|----------------------------------------|---------------------------|
| 23 | Command and Scripting Interpreter      | <a href="#">T1059</a>     |
| 24 | Data Transfer Size Limits              | <a href="#">T1030</a>     |
| 25 | Network Service Discovery              | <a href="#">T1046</a>     |
| 26 | Indicator Removal                      | <a href="#">T1070</a>     |
| 27 | Archive via Utility                    | <a href="#">T1560.001</a> |
| 28 | Malware                                | <a href="#">T1587.001</a> |
| 29 | System Services                        | <a href="#">T1569</a>     |
| 30 | Query Registry                         | <a href="#">T1012</a>     |
| 31 | Security Software Discovery            | <a href="#">T1518.001</a> |
| 32 | Modify Registry                        | <a href="#">T1112</a>     |
| 33 | Archive Collected Data                 | <a href="#">T1560</a>     |
| 34 | Obtain Capabilities                    | <a href="#">T1588</a>     |
| 35 | Exploitation for Privilege Escalation  | <a href="#">T1068</a>     |
| 36 | Disable or Modify Tools                | <a href="#">T1562.001</a> |
| 37 | PowerShell                             | <a href="#">T1059.001</a> |
| 38 | Develop Capabilities                   | <a href="#">T1587</a>     |
| 39 | Exfiltration Over Alternative Protocol | <a href="#">T1048</a>     |
| 40 | Command and Scripting Interpreter      | <a href="#">T1059</a>     |
| 41 | Unsecured Credentials                  | <a href="#">T1552</a>     |
| 42 | Windows Service                        | <a href="#">T1543.003</a> |
| 43 | Software Discovery                     | <a href="#">T1518</a>     |
| 44 | Data Encrypted for Impact              | <a href="#">T1486</a>     |
| 45 | OS Credential Dumping                  | <a href="#">T1003</a>     |
| 46 | Domain Account                         | <a href="#">T1087.002</a> |
| 47 | System Network Configuration Discovery | <a href="#">T1016</a>     |
| 48 | Clear Windows Event Logs               | <a href="#">T1070.001</a> |
| 49 | Remote System Discovery                | <a href="#">T1018</a>     |
| 50 | Valid Accounts                         | <a href="#">T1078</a>     |
| 51 | OS Credential Dumping                  | <a href="#">T1003</a>     |
| 52 | Process Discovery                      | <a href="#">T1057</a>     |

|    | Name                              | MITRE ID                  |
|----|-----------------------------------|---------------------------|
| 53 | Web Service                       | <a href="#">T1102</a>     |
| 54 | Obfuscated Files or Information   | <a href="#">T1027</a>     |
| 55 | Service Execution                 | <a href="#">T1569.002</a> |
| 56 | Indicator Removal                 | <a href="#">T1070</a>     |
| 57 | Valid Accounts                    | <a href="#">T1078</a>     |
| 58 | Virtualization/Sandbox Evasion    | <a href="#">T1497</a>     |
| 59 | Python                            | <a href="#">T1059.006</a> |
| 60 | Local Accounts                    | <a href="#">T1078.003</a> |
| 61 | Local Account                     | <a href="#">T1087.001</a> |
| 62 | Account Discovery                 | <a href="#">T1087</a>     |
| 63 | SSH                               | <a href="#">T1021.004</a> |
| 64 | System Owner/User Discovery       | <a href="#">T1033</a>     |
| 65 | Impair Defenses                   | <a href="#">T1562</a>     |
| 66 | Ingress Tool Transfer             | <a href="#">T1105</a>     |
| 67 | Exploit Public-Facing Application | <a href="#">T1190</a>     |
| 68 | System Information Discovery      | <a href="#">T1082</a>     |
| 69 | Remote Services                   | <a href="#">T1021</a>     |
| 70 | Archive Collected Data            | <a href="#">T1560</a>     |
| 71 | Impair Defenses                   | <a href="#">T1562</a>     |
| 72 | Obfuscated Files or Information   | <a href="#">T1027</a>     |
| 73 | External Remote Services          | <a href="#">T1133</a>     |
| 74 | File Deletion                     | <a href="#">T1070.004</a> |
| 75 | Encrypted Channel                 | <a href="#">T1573</a>     |
| 76 | Lateral Tool Transfer             | <a href="#">T1570</a>     |
| 77 | Internal Defacement               | <a href="#">T1491.001</a> |
| 78 | Service Stop                      | <a href="#">T1489</a>     |
| 79 | Tool                              | <a href="#">T1588.002</a> |
| 80 | Proxy                             | <a href="#">T1090</a>     |
| 81 | File and Directory Discovery      | <a href="#">T1083</a>     |

## Appendix

## Attack Pattern Descriptions

### Command Obfuscation - T1027.010

Adversaries may obfuscate content during command execution to impede detection. Command-line obfuscation is a method of making strings and patterns within commands and scripts more difficult to signature and analyze. This type of obfuscation can be included within commands executed by delivered payloads (e.g., [Phishing](#) and [Drive-by Compromise](#)) or interactively via [Command and Scripting Interpreter](#). (Citation: Akamai JS)(Citation: Malware Monday VBE)

For example, adversaries may abuse syntax that utilizes various symbols and escape characters (such as spacing, ^, +, \$, and %) to make commands difficult to analyze while maintaining the same intended functionality.(Citation: RC PowerShell) Many languages support built-in obfuscation in the form of base64 or URL encoding.(Citation: Microsoft PowerShellB64) Adversaries may also manually implement command obfuscation via string splitting ("[Wor](#)"+"[d.Application](#)"), order and casing of characters ([rev <<<'dwssap/cte/ tac'](#)"), globing ([mkdir -p '/tmp/:&\\$NiA'](#)), as well as various tricks involving passing strings through tokens/environment variables/input streams.(Citation: Bashfuscator Command Obfuscators) (Citation: FireEye Obfuscation June 2017)

Adversaries may also use tricks such as directory traversals to obfuscate references to the binary being invoked by a command

([C:\voi\pcw\...\Windows\tei\qs\k\...\system32\erool\...\wbem\wg\je\...\wmic.exe shadowcopy delete](#)).(Citation: Twitter Richard WMIC)

Tools such as [Invoke-Obfuscation](#) and [Invoke-DOSfuscation](#) have also been used to obfuscate commands. (Citation: Invoke-DOSfuscation)(Citation: Invoke-Obfuscation)

### Malicious File - T1204.002

An adversary may rely upon a user opening a malicious file in order to gain execution. Users may be subjected to social engineering to get them to open a file that will lead to code execution. This user action will typically be observed as follow-on behavior from [Spearphishing Attachment](#). Adversaries may use several types of files that require a user to execute them, including .doc, .pdf, .xls, .rtf, .scr, .exe, .lnk, .pif, .cpl, .reg, and .iso.(Citation: Mandiant Trojanized Windows 10)

Adversaries may employ various forms of [Masquerading](#) and [Obfuscated Files or Information](#) to increase the likelihood that a user will open and successfully execute a malicious file. These methods may include using a familiar naming convention and/or password protecting the file and supplying instructions to a user on how to open it.(Citation: Password Protected Word Docs)

While [Malicious File](#) frequently occurs shortly after Initial Access it may occur at other phases of an intrusion, such as when an adversary places a file in a shared directory or on a user's desktop hoping that a user will click on it. This activity may also be seen shortly after [Internal Spearphishing](#).

### Dynamic Resolution - T1568

Adversaries may dynamically establish connections to command and control infrastructure to evade common detections and remediations. This may be achieved by using malware that shares a common algorithm with the infrastructure the adversary uses to receive the malware's communications. These calculations can be used

to dynamically adjust parameters such as the domain name, IP address, or port number the malware uses for command and control.

Adversaries may use dynamic resolution for the purpose of [Fallback Channels](#). When contact is lost with the primary command and control server malware may employ dynamic resolution as a means to reestablishing command and control.(Citation: Talos CCleanup 2017)(Citation: FireEye POSHSPY April 2017)(Citation: ESET Sednit 2017 Activity)

### **Domain or Tenant Policy Modification - [T1484](#)**

Adversaries may modify the configuration settings of a domain or identity tenant to evade defenses and/or escalate privileges in centrally managed environments. Such services provide a centralized means of managing identity resources such as devices and accounts, and often include configuration settings that may apply between domains or tenants such as trust relationships, identity syncing, or identity federation.

Modifications to domain or tenant settings may include altering domain Group Policy Objects (GPOs) in Microsoft Active Directory (AD) or changing trust settings for domains, including federation trusts relationships between domains or tenants.

With sufficient permissions, adversaries can modify domain or tenant policy settings. Since configuration settings for these services apply to a large number of identity resources, there are a great number of potential attacks malicious outcomes that can stem from this abuse. Examples of such abuse include:

- modifying GPOs to push a malicious [Scheduled Task](#) to computers throughout the domain environment(Citation: ADSecurity GPO Persistence 2016)(Citation: Wald0 Guide to GPOs)(Citation: Harmj0y Abusing GPO Permissions)
- modifying domain trusts to include an adversary-controlled domain, allowing adversaries to forge access tokens that will subsequently be accepted by victim domain resources(Citation: Microsoft - Customer Guidance on Recent Nation-State Cyber Attacks)
- changing configuration settings within the AD environment to implement a [Rogue Domain Controller](#).
- adding new, adversary-controlled federated identity providers to identity tenants, allowing adversaries to authenticate as any user managed by the victim tenant (Citation: Okta Cross-Tenant Impersonation 2023)

Adversaries may temporarily modify domain or tenant policy, carry out a malicious action(s), and then revert the change to remove suspicious indicators.

### **Defacement - [T1491](#)**

Adversaries may modify visual content available internally or externally to an enterprise network, thus affecting the integrity of the original content. Reasons for [Defacement](#) include delivering messaging, intimidation, or claiming (possibly false) credit for an intrusion. Disturbing or offensive images may be used as a part of [Defacement](#) in order to cause user discomfort, or to pressure compliance with accompanying messages.

### **System Network Connections Discovery - [T1049](#)**

Adversaries may attempt to get a listing of network connections to or from the compromised system they are currently accessing or from remote systems by querying for information over the network.



An adversary who gains access to a system that is part of a cloud-based environment may map out Virtual Private Clouds or Virtual Networks in order to determine what systems and services are connected. The actions performed are likely the same types of discovery techniques depending on the operating system, but the resulting information may include details about the networked cloud environment relevant to the adversary's goals. Cloud providers may have different ways in which their virtual networks operate.(Citation: Amazon AWS VPC Guide)(Citation: Microsoft Azure Virtual Network Overview)(Citation: Google VPC Overview) Similarly, adversaries who gain access to network devices may also perform similar discovery activities to gather information about connected systems and services.

Utilities and commands that acquire this information include `netstat`, "net use," and "net session" with `Net`. In Mac and Linux, `netstat` and `lsof` can be used to list current connections. `who -a` and `w` can be used to show which users are currently logged in, similar to "net session". Additionally, built-in features native to network devices and `Network Device CLI` may be used (e.g. `show ip sockets`, `show tcp brief`).(Citation: US-CERT-TA18-106A) On ESXi servers, the command `esxi network ip connection list` can be used to list active network connections.(Citation: Sygnia ESXi Ransomware 2025)

### Create or Modify System Process - T1543

Adversaries may create or modify system-level processes to repeatedly execute malicious payloads as part of persistence. When operating systems boot up, they can start processes that perform background system functions. On Windows and Linux, these system processes are referred to as services.(Citation: TechNet Services) On macOS, launchd processes known as `Launch Daemon` and `Launch Agent` are run to finish system initialization and load user specific parameters.(Citation: AppleDocs Launch Agent Daemons)

Adversaries may install new services, daemons, or agents that can be configured to execute at startup or a repeatable interval in order to establish persistence. Similarly, adversaries may modify existing services, daemons, or agents to achieve the same effect.

Services, daemons, or agents may be created with administrator privileges but executed under root/SYSTEM privileges. Adversaries may leverage this functionality to create or modify system processes in order to escalate privileges.(Citation: OSX Malware Detection)

### SMB/Windows Admin Shares - T1021.002

Adversaries may use `Valid Accounts` to interact with a remote network share using Server Message Block (SMB). The adversary may then perform actions as the logged-on user.

SMB is a file, printer, and serial port sharing protocol for Windows machines on the same network or domain. Adversaries may use SMB to interact with file shares, allowing them to move laterally throughout a network. Linux and macOS implementations of SMB typically use Samba.

Windows systems have hidden network shares that are accessible only to administrators and provide the ability for remote file copy and other administrative functions. Example network shares include `C$`, `ADMIN$`, and `IPC$`. Adversaries may use this technique in conjunction with administrator-level `Valid Accounts` to remotely access a networked system over SMB,(Citation: Wikipedia Server Message Block) to interact with systems using remote procedure calls (RPCs),(Citation: TechNet RPC) transfer files, and run transferred binaries through remote Execution. Example execution techniques that rely on authenticated sessions over SMB/RPC are `Scheduled Task/Job`, `Service Execution`, and `Windows Management Instrumentation`. Adversaries can also

use NTLM hashes to access administrator shares on systems with [Pass the Hash](#) and certain configuration and patch levels.(Citation: Microsoft Admin Shares)

### Software Packing - T1027.002

Adversaries may perform software packing or virtual machine software protection to conceal their code. Software packing is a method of compressing or encrypting an executable. Packing an executable changes the file signature in an attempt to avoid signature-based detection. Most decompression techniques decompress the executable code in memory. Virtual machine software protection translates an executable's original code into a special format that only a special virtual machine can run. A virtual machine is then called to run this code.(Citation: ESET FinFisher Jan 2018)

Utilities used to perform software packing are called packers. Example packers are MPRESS and UPX. A more comprehensive list of known packers is available, but adversaries may create their own packing techniques that do not leave the same artifacts as well-known packers to evade defenses.(Citation: Awesome Executable Packing)

### Account Access Removal - T1531

Adversaries may interrupt availability of system and network resources by inhibiting access to accounts utilized by legitimate users. Accounts may be deleted, locked, or manipulated (ex: changed credentials, revoked permissions for SaaS platforms such as Sharepoint) to remove access to accounts.(Citation: Obsidian Security SaaS Ransomware June 2023) Adversaries may also subsequently log off and/or perform a [System Shutdown/Reboot](#) to set malicious changes into place.(Citation: CarbonBlack LockerGoga 2019)(Citation: Unit42 LockerGoga 2019)

In Windows, [Net](#) utility, [Set-LocalUser](#) and [Set-ADAccountPassword](#) [PowerShell](#) cmdlets may be used by adversaries to modify user accounts. Accounts could also be disabled by Group Policy. In Linux, the [passwd](#) utility may be used to change passwords. On ESXi servers, accounts can be removed or modified via [esxcli \(system account set, system account remove\)](#).

Adversaries who use ransomware or similar attacks may first perform this and other Impact behaviors, such as [Data Destruction](#) and [Defacement](#), in order to impede incident response/recovery before completing the [Data Encrypted for Impact](#) objective.

### Deobfuscate/Decode Files or Information - T1140

Adversaries may use [Obfuscated Files or Information](#) to hide artifacts of an intrusion from analysis. They may require separate mechanisms to decode or deobfuscate that information depending on how they intend to use it. Methods for doing that include built-in functionality of malware or by using utilities present on the system.

One such example is the use of [certutil](#) to decode a remote access tool portable executable file that has been hidden inside a certificate file.(Citation: Malwarebytes Targeted Attack against Saudi Arabia) Another example is using the Windows [copy /b](#) or [type](#) command to reassemble binary fragments into a malicious payload. (Citation: Carbon Black Obfuscation Sept 2016)(Citation: Sentinel One Tainted Love 2023)

Sometimes a user's action may be required to open it for deobfuscation or decryption as part of [User Execution](#). The user may also be required to input a password to open a password protected

compressed/encrypted file that was provided by the adversary.(Citation: Volexity PowerDuke November 2016)

## **Software Discovery - T1518**

Adversaries may attempt to get a listing of software and software versions that are installed on a system or in a cloud environment. Adversaries may use the information from [Software Discovery](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

Such software may be deployed widely across the environment for configuration management or security reasons, such as [Software Deployment Tools](#), and may allow adversaries broad access to infect devices or move laterally.

Adversaries may attempt to enumerate software for a variety of reasons, such as figuring out what security measures are present or if the compromised system has a version of software that is vulnerable to [Exploitation for Privilege Escalation](#).

## **Remote Services - T1021**

Adversaries may use [Valid Accounts](#) to log into a service that accepts remote connections, such as telnet, SSH, and VNC. The adversary may then perform actions as the logged-on user.

In an enterprise environment, servers and workstations can be organized into domains. Domains provide centralized identity management, allowing users to login using one set of credentials across the entire network. If an adversary is able to obtain a set of valid domain credentials, they could login to many different machines using remote access protocols such as secure shell (SSH) or remote desktop protocol (RDP). (Citation: SSH Secure Shell)(Citation: TechNet Remote Desktop Services) They could also login to accessible SaaS or IaaS services, such as those that federate their identities to the domain, or management platforms for internal virtualization environments such as VMware vCenter.

Legitimate applications (such as [Software Deployment Tools](#) and other administrative programs) may utilize [Remote Services](#) to access remote hosts. For example, Apple Remote Desktop (ARD) on macOS is native software used for remote management. ARD leverages a blend of protocols, including [VNC](#) to send the screen and control buffers and [SSH](#) for secure file transfer.(Citation: Remote Management MDM macOS)(Citation: Kickstart Apple Remote Desktop commands)(Citation: Apple Remote Desktop Admin Guide 3.3) Adversaries can abuse applications such as ARD to gain remote code execution and perform lateral movement. In versions of macOS prior to 10.14, an adversary can escalate an SSH session to an ARD session which enables an adversary to accept TCC (Transparency, Consent, and Control) prompts without user interaction and gain access to data.(Citation: FireEye 2019 Apple Remote Desktop)(Citation: Lockboxx ARD 2019)(Citation: Kickstart Apple Remote Desktop commands)

## **T1009 - T1009**

None

## **Server Software Component - T1505**

Adversaries may abuse legitimate extensible development features of servers to establish persistent access to systems. Enterprise server applications may include features that allow developers to write and install software

or scripts to extend the functionality of the main application. Adversaries may install malicious components to extend and abuse server applications.(Citation: volexity\_0day\_sophos\_FW)

## Domain Generation Algorithms - T1568.002

Adversaries may make use of Domain Generation Algorithms (DGAs) to dynamically identify a destination domain for command and control traffic rather than relying on a list of static IP addresses or domains. This has the advantage of making it much harder for defenders to block, track, or take over the command and control channel, as there potentially could be thousands of domains that malware can check for instructions. (Citation: Cybereason Dissecting DGAs)(Citation: Cisco Umbrella DGA)(Citation: Unit 42 DGA Feb 2019)

DGAs can take the form of apparently random or “gibberish” strings (ex: istgmxdejdnxuyla.ru) when they construct domain names by generating each letter. Alternatively, some DGAs employ whole words as the unit by concatenating words together instead of letters (ex: cityjulydish.net). Many DGAs are time-based, generating a different domain for each time period (hourly, daily, monthly, etc). Others incorporate a seed value as well to make predicting future domains more difficult for defenders.(Citation: Cybereason Dissecting DGAs)(Citation: Cisco Umbrella DGA)(Citation: Talos CCleanup 2017)(Citation: Akamai DGA Mitigation)

Adversaries may use DGAs for the purpose of [Fallback Channels](#). When contact is lost with the primary command and control server malware may employ a DGA as a means to reestablishing command and control. (Citation: Talos CCleanup 2017)(Citation: FireEye POSHSPY April 2017)(Citation: ESET Sednit 2017 Activity)

## Windows Command Shell - T1059.003

Adversaries may abuse the Windows command shell for execution. The Windows command shell ([cmd](#)) is the primary command prompt on Windows systems. The Windows command prompt can be used to control almost any aspect of a system, with various permission levels required for different subsets of commands. The command prompt can be invoked remotely via [Remote Services](#) such as [SSH](#).(Citation: SSH in Windows)

Batch files (ex: .bat or .cmd) also provide the shell with a list of sequential commands to run, as well as normal scripting operations such as conditionals and loops. Common uses of batch files include long or repetitive tasks, or the need to run the same set of commands on multiple systems.

Adversaries may leverage [cmd](#) to execute various commands and payloads. Common uses include [cmd](#) to execute a single command, or abusing [cmd](#) interactively with input and output forwarded over a command and control channel.

## User Execution - T1204

An adversary may rely upon specific actions by a user in order to gain execution. Users may be subjected to social engineering to get them to execute malicious code by, for example, opening a malicious document file or link. These user actions will typically be observed as follow-on behavior from forms of [Phishing](#).

While [User Execution](#) frequently occurs shortly after Initial Access it may occur at other phases of an intrusion, such as when an adversary places a file in a shared directory or on a user's desktop hoping that a user will click on it. This activity may also be seen shortly after [Internal Spearphishing](#).

Adversaries may also deceive users into performing actions such as:

- Enabling [Remote Access Tools](#), allowing direct control of the system to the adversary

- Running malicious JavaScript in their browser, allowing adversaries to [Steal Web Session Cookies](#)(Citation: Talos Roblox Scam 2023)(Citation: Krebs Discord Bookmarks 2023)
- Downloading and executing malware for [User Execution](#)
- Coercing users to copy, paste, and execute malicious code manually(Citation: Reliaquest-execution) (Citation: proofpoint-selfpwn)

For example, tech support scams can be facilitated through [Phishing](#), vishing, or various forms of user interaction. Adversaries can use a combination of these methods, such as spoofing and promoting toll-free numbers or call centers that are used to direct victims to malicious websites, to deliver and execute payloads containing malware or [Remote Access Tools](#).(Citation: Telephone Attack Delivery)

### **Exfiltration Over C2 Channel - [T1041](#)**

Adversaries may steal data by exfiltrating it over an existing command and control channel. Stolen data is encoded into the normal communications channel using the same protocol as command and control communications.

### **Domain Accounts - [T1078.002](#)**

Adversaries may obtain and abuse credentials of a domain account as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.(Citation: TechNet Credential Theft) Domain accounts are those managed by Active Directory Domain Services where access and permissions are configured across systems and services that are part of that domain. Domain accounts can cover users, administrators, and services.(Citation: Microsoft AD Accounts)

Adversaries may compromise domain accounts, some with a high level of privileges, through various means such as [OS Credential Dumping](#) or password reuse, allowing access to privileged resources of the domain.

### **Financial Theft - [T1657](#)**

Adversaries may steal monetary resources from targets through extortion, social engineering, technical theft, or other methods aimed at their own financial gain at the expense of the availability of these resources for victims. Financial theft is the ultimate objective of several popular campaign types including extortion by ransomware,(Citation: FBI-ransomware) business email compromise (BEC) and fraud,(Citation: FBI-BEC) "pig butchering,"(Citation: wired-pig butchering) bank hacking,(Citation: DOJ-DPRK Heist) and exploiting cryptocurrency networks.(Citation: BBC-Ronin)

Adversaries may [Compromise Accounts](#) to conduct unauthorized transfers of funds.(Citation: Internet crime report 2022) In the case of business email compromise or email fraud, an adversary may utilize [Impersonation](#) of a trusted entity. Once the social engineering is successful, victims can be deceived into sending money to financial accounts controlled by an adversary.(Citation: FBI-BEC) This creates the potential for multiple victims (i.e., compromised accounts as well as the ultimate monetary loss) in incidents involving financial theft. (Citation: VEC)

Extortion by ransomware may occur, for example, when an adversary demands payment from a victim after [Data Encrypted for Impact](#) (Citation: NYT-Colonial) and [Exfiltration](#) of data, followed by threatening to leak sensitive data to the public unless payment is made to the adversary.(Citation: Mandiant-leaks) Adversaries may use dedicated leak sites to distribute victim data.(Citation: Crowdstrike-leaks)

Due to the potentially immense business impact of financial theft, an adversary may abuse the possibility of financial theft and seeking monetary gain to divert attention from their true goals such as [Data Destruction](#) and business disruption.(Citation: AP-NotPetya)

## Unix Shell - T1059.004

Adversaries may abuse Unix shell commands and scripts for execution. Unix shells are the primary command prompt on Linux, macOS, and ESXi systems, though many variations of the Unix shell exist (e.g. sh, ash, bash, zsh, etc.) depending on the specific OS or distribution.(Citation: DieNet Bash)(Citation: Apple ZShell) Unix shells can control every aspect of a system, with certain commands requiring elevated privileges.

Unix shells also support scripts that enable sequential execution of commands as well as other typical programming operations such as conditionals and loops. Common uses of shell scripts include long or repetitive tasks, or the need to run the same set of commands on multiple systems.

Adversaries may abuse Unix shells to execute various commands or payloads. Interactive shells may be accessed through command and control channels or during lateral movement such as with [SSH](#). Adversaries may also leverage shell scripts to deliver and execute multiple commands on victims or as part of payloads used for persistence.

Some systems, such as embedded devices, lightweight Linux distributions, and ESXi servers, may leverage stripped-down Unix shells via Busybox, a small executable that contains a variety of tools, including a simple shell.

## LSASS Memory - T1003.001

Adversaries may attempt to access credential material stored in the process memory of the Local Security Authority Subsystem Service (LSASS). After a user logs on, the system generates and stores a variety of credential materials in LSASS process memory. These credential materials can be harvested by an administrative user or SYSTEM and used to conduct [Lateral Movement](#) using [Use Alternate Authentication Material](#).

As well as in-memory techniques, the LSASS process memory can be dumped from the target host and analyzed on a local system.

For example, on the target host use procdump:

- `procdump -ma lsass.exe lsass_dump`

Locally, mimikatz can be run using:

- `sekurlsa::Minidump lsassdump.dmp`
- `sekurlsa::logonPasswords`

Built-in Windows tools such as `comsvcs.dll` can also be used:

- `rundll32.exe C:\Windows\System32\comsvcs.dll MiniDump PID lsass.dmp full`(Citation: Volatility Exchange Marauder March 2021)(Citation: Symantec Attacks Against Government Sector)

Similar to [Image File Execution Options Injection](#), the silent process exit mechanism can be abused to create a memory dump of `lsass.exe` through Windows Error Reporting (`WerFault.exe`).(Citation: Deep Instinct

## LSASS)

Windows Security Support Provider (SSP) DLLs are loaded into LSASS process at system start. Once loaded into the LSA, SSP DLLs have access to encrypted and plaintext passwords that are stored in Windows, such as any logged-on user's Domain password or smart card PINs. The SSP configuration is stored in two Registry keys: [HKLM\SYSTEM\CurrentControlSet\Control\Lsa\Security Packages](#) and [HKLM\SYSTEM\CurrentControlSet\Control\Lsa\OSConfig\Security Packages](#). An adversary may modify these Registry keys to add new SSPs, which will be loaded the next time the system boots, or when the AddSecurityPackage Windows API function is called.(Citation: Graeber 2014)

The following SSPs can be used to access credentials:

- Msv: Interactive logons, batch logons, and service logons are done through the MSV authentication package.
- Wdigest: The Digest Authentication protocol is designed for use with Hypertext Transfer Protocol (HTTP) and Simple Authentication Security Layer (SASL) exchanges.(Citation: TechNet Blogs Credential Protection)
- Kerberos: Preferred for mutual client-server domain authentication in Windows 2000 and later.
- CredSSP: Provides SSO and Network Level Authentication for Remote Desktop Services.(Citation: TechNet Blogs Credential Protection)

## Command and Scripting Interpreter - T1059

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries. These interfaces and languages provide ways of interacting with computer systems and are a common feature across many different platforms. Most systems come with some built-in command-line interface and scripting capabilities, for example, macOS and Linux distributions include some flavor of [Unix Shell](#) while Windows installations include the [Windows Command Shell](#) and [PowerShell](#).

There are also cross-platform interpreters such as [Python](#), as well as those commonly associated with client applications such as [JavaScript](#) and [Visual Basic](#).

Adversaries may abuse these technologies in various ways as a means of executing arbitrary commands. Commands and scripts can be embedded in [Initial Access](#) payloads delivered to victims as lure documents or as secondary payloads downloaded from an existing C2. Adversaries may also execute commands through interactive terminals/shells, as well as utilize various [Remote Services](#) in order to achieve remote Execution. (Citation: Powershell Remote Commands)(Citation: Cisco IOS Software Integrity Assurance - Command History)(Citation: Remote Shell Execution in Python)

## Data Transfer Size Limits - T1030

An adversary may exfiltrate data in fixed size chunks instead of whole files or limit packet sizes below certain thresholds. This approach may be used to avoid triggering network data transfer threshold alerts.

## Network Service Discovery - T1046

Adversaries may attempt to get a listing of services running on remote hosts and local network infrastructure devices, including those that may be vulnerable to remote software exploitation. Common methods to acquire



this information include port, vulnerability, and/or wordlist scans using tools that are brought onto a system. (Citation: CISA AR21-126A FIVEHANDS May 2021)

Within cloud environments, adversaries may attempt to discover services running on other cloud hosts. Additionally, if the cloud environment is connected to a on-premises environment, adversaries may be able to identify services running on non-cloud systems as well.

Within macOS environments, adversaries may use the native Bonjour application to discover services running on other macOS hosts within a network. The Bonjour mDNSResponder daemon automatically registers and advertises a host's registered services on the network. For example, adversaries can use a mDNS query (such as `dns-sd -B _ssh._tcp .`) to find other systems broadcasting the ssh service. (Citation: apple doco bonjour description) (Citation: macOS APT Activity Bradley)

### Indicator Removal - T1070

Adversaries may delete or modify artifacts generated within systems to remove evidence of their presence or hinder defenses. Various artifacts may be created by an adversary or something that can be attributed to an adversary's actions. Typically these artifacts are used as defensive indicators related to monitored events, such as strings from downloaded files, logs that are generated from user actions, and other data analyzed by defenders. Location, format, and type of artifact (such as command or login history) are often specific to each platform.

Removal of these indicators may interfere with event collection, reporting, or other processes used to detect intrusion activity. This may compromise the integrity of security solutions by causing notable events to go unreported. This activity may also impede forensic analysis and incident response, due to lack of sufficient data to determine what occurred.

### Archive via Utility - T1560.001

Adversaries may use utilities to compress and/or encrypt collected data prior to exfiltration. Many utilities include functionalities to compress, encrypt, or otherwise package data into a format that is easier/more secure to transport.

Adversaries may abuse various utilities to compress or encrypt data before exfiltration. Some third party utilities may be preinstalled, such as `tar` on Linux and macOS or `zip` on Windows systems.

On Windows, `diantz` or `makecab` may be used to package collected files into a cabinet (.cab) file. `diantz` may also be used to download and compress files from remote locations (i.e. [Remote Data Staging](#)). (Citation: `diantz.exe_lolbas`) `xcopy` on Windows can copy files and directories with a variety of options. Additionally, adversaries may use `certutil` to Base64 encode collected data before exfiltration.

Adversaries may use also third party utilities, such as 7-Zip, WinRAR, and WinZip, to perform similar activities. (Citation: 7zip Homepage) (Citation: WinRAR Homepage) (Citation: WinZip Homepage)

### Malware - T1587.001

Adversaries may develop malware and malware components that can be used during targeting. Building malicious software can include the development of payloads, droppers, post-compromise tools, backdoors (including backdoored images), packers, C2 protocols, and the creation of infected removable media.



Adversaries may develop malware to support their operations, creating a means for maintaining control of remote machines, evading defenses, and executing post-compromise behaviors.(Citation: Mandiant APT1)(Citation: Kaspersky Sofacy)(Citation: ActiveMalwareEnergy)(Citation: FBI Flash FIN7 USB)

During malware development, adversaries may intentionally include indicators aligned with other known actors in order to mislead attribution by defenders.(Citation: Olympic Destroyer)(Citation: Risky Bulletin Threat actor impersonates FSB APT)(Citation: GamaCopy organization)

As with legitimate development efforts, different skill sets may be required for developing malware. The skills needed may be located in-house, or may need to be contracted out. Use of a contractor may be considered an extension of that adversary's malware development capabilities, provided the adversary plays a role in shaping requirements and maintains a degree of exclusivity to the malware.

Some aspects of malware development, such as C2 protocol development, may require adversaries to obtain additional infrastructure. For example, malware developed that will communicate with Twitter for C2, may require use of [Web Services](#).(Citation: FireEye APT29)

### **System Services - T1569**

Adversaries may abuse system services or daemons to execute commands or programs. Adversaries can execute malicious content by interacting with or creating services either locally or remotely. Many services are set to run at boot, which can aid in achieving persistence ([Create or Modify System Process](#)), but adversaries can also abuse services for one-time or temporary execution.

### **Query Registry - T1012**

Adversaries may interact with the Windows Registry to gather information about the system, configuration, and installed software.

The Registry contains a significant amount of information about the operating system, configuration, software, and security.(Citation: Wikipedia Windows Registry) Information can easily be queried using the [Reg](#) utility, though other means to access the Registry exist. Some of the information may help adversaries to further their operation within a network. Adversaries may use the information from [Query Registry](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

### **Security Software Discovery - T1518.001**

Adversaries may attempt to get a listing of security software, configurations, defensive tools, and sensors that are installed on a system or in a cloud environment. This may include things such as cloud monitoring agents and anti-virus. Adversaries may use the information from [Security Software Discovery](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

Example commands that can be used to obtain security software information are [netsh](#), [reg query](#) with [Reg](#), [dir](#) with [cmd](#), and [Tasklist](#), but other indicators of discovery behavior may be more specific to the type of software or security system the adversary is looking for. It is becoming more common to see macOS malware perform checks for LittleSnitch and KnockKnock software.

Adversaries may also utilize the [Cloud API](#) to discover cloud-native security software installed on compute infrastructure, such as the AWS CloudWatch agent, Azure VM Agent, and Google Cloud Monitor agent. These agents may collect metrics and logs from the VM, which may be centrally aggregated in a cloud-based monitoring platform.

## **Modify Registry - T1112**

Adversaries may interact with the Windows Registry as part of a variety of other techniques to aid in defense evasion, persistence, and execution.

Access to specific areas of the Registry depends on account permissions, with some keys requiring administrator-level access. The built-in Windows command-line utility [Reg](#) may be used for local or remote Registry modification.(Citation: Microsoft Reg) Other tools, such as remote access tools, may also contain functionality to interact with the Registry through the Windows API.

The Registry may be modified in order to hide configuration information or malicious payloads via [Obfuscated Files or Information](#).(Citation: Unit42 BabyShark Feb 2019)(Citation: Avaddon Ransomware 2021)(Citation: Microsoft BlackCat Jun 2022)(Citation: CISA Russian Gov Critical Infra 2018) The Registry may also be modified to [Impair Defenses](#), such as by enabling macros for all Microsoft Office products, allowing privilege escalation without alerting the user, increasing the maximum number of allowed outbound requests, and/or modifying systems to store plaintext credentials in memory.(Citation: CISA LockBit 2023)(Citation: Unit42 BabyShark Feb 2019)

The Registry of a remote system may be modified to aid in execution of files as part of lateral movement. It requires the remote Registry service to be running on the target system.(Citation: Microsoft Remote) Often [Valid Accounts](#) are required, along with access to the remote system's [SMB/Windows Admin Shares](#) for RPC communication.

Finally, Registry modifications may also include actions to hide keys, such as prepending key names with a null character, which will cause an error and/or be ignored when read via [Reg](#) or other utilities using the Win32 API.(Citation: Microsoft Reghide NOV 2006) Adversaries may abuse these pseudo-hidden keys to conceal payloads/commands used to maintain persistence.(Citation: TrendMicro POWELIKS AUG 2014)(Citation: SpectorOps Hiding Reg Jul 2017)

## **Archive Collected Data - T1560**

An adversary may compress and/or encrypt data that is collected prior to exfiltration. Compressing the data can help to obfuscate the collected data and minimize the amount of data sent over the network.(Citation: DOJ GRU Indictment Jul 2018) Encryption can be used to hide information that is being exfiltrated from detection or make exfiltration less conspicuous upon inspection by a defender.

Both compression and encryption are done prior to exfiltration, and can be performed using a utility, 3rd party library, or custom method.

## **Obtain Capabilities - T1588**

Adversaries may buy and/or steal capabilities that can be used during targeting. Rather than developing their own capabilities in-house, adversaries may purchase, freely download, or steal them. Activities may include the acquisition of malware, software (including licenses), exploits, certificates, and information relating to

vulnerabilities. Adversaries may obtain capabilities to support their operations throughout numerous phases of the adversary lifecycle.

In addition to downloading free malware, software, and exploits from the internet, adversaries may purchase these capabilities from third-party entities. Third-party entities can include technology companies that specialize in malware and exploits, criminal marketplaces, or from individuals.(Citation: NationsBuying)  
(Citation: PegasusCitizenLab)

In addition to purchasing capabilities, adversaries may steal capabilities from third-party entities (including other adversaries). This can include stealing software licenses, malware, SSL/TLS and code-signing certificates, or raiding closed databases of vulnerabilities or exploits.(Citation: DiginotarCompromise)

### **Exploitation for Privilege Escalation - T1068**

Adversaries may exploit software vulnerabilities in an attempt to elevate privileges. Exploitation of a software vulnerability occurs when an adversary takes advantage of a programming error in a program, service, or within the operating system software or kernel itself to execute adversary-controlled code. Security constructs such as permission levels will often hinder access to information and use of certain techniques, so adversaries will likely need to perform privilege escalation to include use of software exploitation to circumvent those restrictions.

When initially gaining access to a system, an adversary may be operating within a lower privileged process which will prevent them from accessing certain resources on the system. Vulnerabilities may exist, usually in operating system components and software commonly running at higher permissions, that can be exploited to gain higher levels of access on the system. This could enable someone to move from unprivileged or user level permissions to SYSTEM or root permissions depending on the component that is vulnerable. This could also enable an adversary to move from a virtualized environment, such as within a virtual machine or container, onto the underlying host. This may be a necessary step for an adversary compromising an endpoint system that has been properly configured and limits other privilege escalation methods.

Adversaries may bring a signed vulnerable driver onto a compromised machine so that they can exploit the vulnerability to execute code in kernel mode. This process is sometimes referred to as Bring Your Own Vulnerable Driver (BYOVD).(Citation: ESET InvisiMole June 2020)(Citation: Unit42 AcidBox June 2020)

Adversaries may include the vulnerable driver with files delivered during Initial Access or download it to a compromised system via [Ingress Tool Transfer](#) or [Lateral Tool Transfer](#).

### **Disable or Modify Tools - T1562.001**

Adversaries may modify and/or disable security tools to avoid possible detection of their malware/tools and activities. This may take many forms, such as killing security software processes or services, modifying / deleting Registry keys or configuration files so that tools do not operate properly, or other methods to interfere with security tools scanning or reporting information. Adversaries may also disable updates to prevent the latest security patches from reaching tools on victim systems.(Citation: SCADAfence\_ransomware)

Adversaries may trigger a denial-of-service attack via legitimate system processes. It has been previously observed that the Windows Time Travel Debugging (TTD) monitor driver can be used to initiate a debugging session for a security tool (e.g., an EDR) and render the tool non-functional. By hooking the debugger into the EDR process, all child processes from the EDR will be automatically suspended. The attacker can terminate any EDR helper processes (unprotected by Windows Protected Process Light) by abusing the Process Explorer

driver. In combination this will halt any attempt to restart services and cause the tool to crash.(Citation: Cocomazzi FIN7 Reboot)

Adversaries may also tamper with artifacts deployed and utilized by security tools. Security tools may make dynamic changes to system components in order to maintain visibility into specific events. For example, security products may load their own modules and/or modify those loaded by processes to facilitate data collection. Similar to [Indicator Blocking](#), adversaries may unhook or otherwise modify these features added by tools (especially those that exist in userland or are otherwise potentially accessible to adversaries) to avoid detection.(Citation: OutFlank System Calls)(Citation: MDSec System Calls) For example, adversaries may abuse the Windows process mitigation policy to block certain endpoint detection and response (EDR) products from loading their user-mode code via DLLs. By spawning a process with the `PROCESS_CREATION_MITIGATION_POLICY_BLOCK_NON_MICROSOFT_BINARIES_ALWAYS_ON` attribute using API calls like `UpdateProcThreadAttribute`, adversaries may evade detection by endpoint security solutions that rely on DLLs that are not signed by Microsoft. Alternatively, they may add new directories to an EDR tool's exclusion list, enabling them to hide malicious files via [File/Path Exclusions](#).(Citation: BlackBerry WhisperGate 2022)(Citation: Google Cloud Threat Intelligence FIN13 2021)

Adversaries may also focus on specific applications such as Sysmon. For example, the "Start" and "Enable" values in `HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\WMI\AutoLogger\EventLog-Microsoft-Windows-Sysmon-Operational` may be modified to tamper with and potentially disable Sysmon logging.(Citation: disable\_win\_evt\_logging)

On network devices, adversaries may attempt to skip digital signature verification checks by altering startup configuration files and effectively disabling firmware verification that typically occurs at boot.(Citation: Fortinet Zero-Day and Custom Malware Used by Suspected Chinese Actor in Espionage Operation)(Citation: Analysis of FG-IR-22-369)

In cloud environments, tools disabled by adversaries may include cloud monitoring agents that report back to services such as AWS CloudWatch or Google Cloud Monitor.

Furthermore, although defensive tools may have anti-tampering mechanisms, adversaries may abuse tools such as legitimate rootkit removal kits to impair and/or disable these tools.(Citation: chasing\_avaddon\_ransomware)(Citation: dharma\_ransomware)(Citation: demystifying\_ryuk)(Citation: doppelpaymer\_crowdstrike) For example, adversaries have used tools such as GMER to find and shut down hidden processes and antivirus software on infected systems.(Citation: demystifying\_ryuk)

Additionally, adversaries may exploit legitimate drivers from anti-virus software to gain access to kernel space (i.e. [Exploitation for Privilege Escalation](#)), which may lead to bypassing anti-tampering features.(Citation: avoslocker\_ransomware)

## PowerShell - T1059.001

Adversaries may abuse PowerShell commands and scripts for execution. PowerShell is a powerful interactive command-line interface and scripting environment included in the Windows operating system.(Citation: TechNet PowerShell) Adversaries can use PowerShell to perform a number of actions, including discovery of information and execution of code. Examples include the `Start-Process` cmdlet which can be used to run an executable and the `Invoke-Command` cmdlet which runs a command locally or on a remote computer (though administrator permissions are required to use PowerShell to connect to remote systems).

PowerShell may also be used to download and run executables from the Internet, which can be executed from disk or in memory without touching disk.

A number of PowerShell-based offensive testing tools are available, including [Empire](#), [PowerSploit](#), [PoshC2](#), and PSAttack.(Citation: Github PSAttack)

PowerShell commands/scripts can also be executed without directly invoking the [powershell.exe](#) binary through interfaces to PowerShell's underlying [System.Management.Automation](#) assembly DLL exposed through the .NET framework and Windows Common Language Interface (CLI).(Citation: Sixdub PowerPick Jan 2016)(Citation: SilentBreak Offensive PS Dec 2015)(Citation: Microsoft PSfromCsharp APR 2014)

## **Develop Capabilities - T1587**

Adversaries may build capabilities that can be used during targeting. Rather than purchasing, freely downloading, or stealing capabilities, adversaries may develop their own capabilities in-house. This is the process of identifying development requirements and building solutions such as malware, exploits, and self-signed certificates. Adversaries may develop capabilities to support their operations throughout numerous phases of the adversary lifecycle.(Citation: Mandiant APT1)(Citation: Kaspersky Sofacy)(Citation: Bitdefender StrongPity June 2020)(Citation: Talos Promethium June 2020)

As with legitimate development efforts, different skill sets may be required for developing capabilities. The skills needed may be located in-house, or may need to be contracted out. Use of a contractor may be considered an extension of that adversary's development capabilities, provided the adversary plays a role in shaping requirements and maintains a degree of exclusivity to the capability.

## **Exfiltration Over Alternative Protocol - T1048**

Adversaries may steal data by exfiltrating it over a different protocol than that of the existing command and control channel. The data may also be sent to an alternate network location from the main command and control server.

Alternate protocols include FTP, SMTP, HTTP/S, DNS, SMB, or any other network protocol not being used as the main command and control channel. Adversaries may also opt to encrypt and/or obfuscate these alternate channels.

[Exfiltration Over Alternative Protocol](#) can be done using various common operating system utilities such as [Net](#)/SMB or FTP.(Citation: Palo Alto OilRig Oct 2016) On macOS and Linux [curl](#) may be used to invoke protocols such as HTTP/S or FTP/S to exfiltrate data from a system.(Citation: 20 macOS Common Tools and Techniques)

Many IaaS and SaaS platforms (such as Microsoft Exchange, Microsoft SharePoint, GitHub, and AWS S3) support the direct download of files, emails, source code, and other sensitive information via the web console or [Cloud API](#).

## **Command and Scripting Interpreter - T1059**

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries. These interfaces and languages provide ways of interacting with computer systems and are a common feature across many different platforms. Most systems come with some built-in command-line interface and scripting

capabilities, for example, macOS and Linux distributions include some flavor of [Unix Shell](#) while Windows installations include the [Windows Command Shell](#) and [PowerShell](#).

There are also cross-platform interpreters such as [Python](#), as well as those commonly associated with client applications such as [JavaScript](#) and [Visual Basic](#).

Adversaries may abuse these technologies in various ways as a means of executing arbitrary commands. Commands and scripts can be embedded in [Initial Access](#) payloads delivered to victims as lure documents or as secondary payloads downloaded from an existing C2. Adversaries may also execute commands through interactive terminals/shells, as well as utilize various [Remote Services](#) in order to achieve remote Execution. (Citation: Powershell Remote Commands)(Citation: Cisco IOS Software Integrity Assurance - Command History)(Citation: Remote Shell Execution in Python)

### **Unsecured Credentials - T1552**

Adversaries may search compromised systems to find and obtain insecurely stored credentials. These credentials can be stored and/or misplaced in many locations on a system, including plaintext files (e.g. [Shell History](#)), operating system or application-specific repositories (e.g. [Credentials in Registry](#)), or other specialized files/artifacts (e.g. [Private Keys](#)). (Citation: Brining MimiKatz to Unix)

### **Windows Service - T1543.003**

Adversaries may create or modify Windows services to repeatedly execute malicious payloads as part of persistence. When Windows boots up, it starts programs or applications called services that perform background system functions. (Citation: TechNet Services) Windows service configuration information, including the file path to the service's executable or recovery programs/commands, is stored in the Windows Registry.

Adversaries may install a new service or modify an existing service to execute at startup in order to persist on a system. Service configurations can be set or modified using system utilities (such as `sc.exe`), by directly modifying the Registry, or by interacting directly with the Windows API.

Adversaries may also use services to install and execute malicious drivers. For example, after dropping a driver file (ex: `.sys`) to disk, the payload can be loaded and registered via [Native API](#) functions such as `CreateServiceW()` (or manually via functions such as `ZwLoadDriver()` and `ZwSetValueKey()`), by creating the required service Registry values (i.e. [Modify Registry](#)), or by using command-line utilities such as `PnPUtl.exe`. (Citation: Symantec W.32 Stuxnet Dossier)(Citation: CrowdStrike DriveSlayer February 2022) (Citation: Unit42 AcidBox June 2020) Adversaries may leverage these drivers as [Rootkits](#) to hide the presence of malicious activity on a system. Adversaries may also load a signed yet vulnerable driver onto a compromised machine (known as "Bring Your Own Vulnerable Driver" (BYOVD)) as part of [Exploitation for Privilege Escalation](#). (Citation: ESET InvisiMole June 2020)(Citation: Unit42 AcidBox June 2020)

Services may be created with administrator privileges but are executed under SYSTEM privileges, so an adversary may also use a service to escalate privileges. Adversaries may also directly start services through [Service Execution](#).

To make detection analysis more challenging, malicious services may also incorporate [Masquerade Task or Service](#) (ex: using a service and/or payload name related to a legitimate OS or benign software component). Adversaries may also create 'hidden' services (i.e., [Hide Artifacts](#)), for example by using the `sc sdset`



command to set service permissions via the Service Descriptor Definition Language (SDDL). This may hide a Windows service from the view of standard service enumeration methods such as [Get-Service](#), [sc query](#), and [services.exe](#).(Citation: SANS 1)(Citation: SANS 2)

## Software Discovery - T1518

Adversaries may attempt to get a listing of software and software versions that are installed on a system or in a cloud environment. Adversaries may use the information from [Software Discovery](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

Such software may be deployed widely across the environment for configuration management or security reasons, such as [Software Deployment Tools](#), and may allow adversaries broad access to infect devices or move laterally.

Adversaries may attempt to enumerate software for a variety of reasons, such as figuring out what security measures are present or if the compromised system has a version of software that is vulnerable to [Exploitation for Privilege Escalation](#).

## Data Encrypted for Impact - T1486

Adversaries may encrypt data on target systems or on large numbers of systems in a network to interrupt availability to system and network resources. They can attempt to render stored data inaccessible by encrypting files or data on local and remote drives and withholding access to a decryption key. This may be done in order to extract monetary compensation from a victim in exchange for decryption or a decryption key (ransomware) or to render data permanently inaccessible in cases where the key is not saved or transmitted. (Citation: US-CERT Ransomware 2016)(Citation: FireEye WannaCry 2017)(Citation: US-CERT NotPetya 2017) (Citation: US-CERT SamSam 2018)

In the case of ransomware, it is typical that common user files like Office documents, PDFs, images, videos, audio, text, and source code files will be encrypted (and often renamed and/or tagged with specific file markers). Adversaries may need to first employ other behaviors, such as [File and Directory Permissions Modification](#) or [System Shutdown/Reboot](#), in order to unlock and/or gain access to manipulate these files. (Citation: CarbonBlack Conti July 2020) In some cases, adversaries may encrypt critical system files, disk partitions, and the MBR.(Citation: US-CERT NotPetya 2017) Adversaries may also encrypt virtual machines hosted on ESXi or other hypervisors.(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)

To maximize impact on the target organization, malware designed for encrypting data may have worm-like features to propagate across a network by leveraging other attack techniques like [Valid Accounts](#), [OS Credential Dumping](#), and [SMB/Windows Admin Shares](#).(Citation: FireEye WannaCry 2017)(Citation: US-CERT NotPetya 2017) Encryption malware may also leverage [Internal Defacement](#), such as changing victim wallpapers or ESXi server login messages, or otherwise intimidate victims by sending ransom notes or other messages to connected printers (known as "print bombing").(Citation: NHS Digital Egregor Nov 2020) (Citation: Varonis)

In cloud environments, storage objects within compromised accounts may also be encrypted.(Citation: Rhino S3 Ransomware Part 1) For example, in AWS environments, adversaries may leverage services such as AWS's Server-Side Encryption with Customer Provided Keys (SSE-C) to encrypt data.(Citation: Halcyon AWS Ransomware 2025)

## OS Credential Dumping - T1003

Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password. Credentials can be obtained from OS caches, memory, or structures. (Citation: Brining MimiKatz to Unix) Credentials can then be used to perform [Lateral Movement](#) and access restricted information.

Several of the tools mentioned in associated sub-techniques may be used by both adversaries and professional security testers. Additional custom tools likely exist as well.

## Domain Account - T1087.002

Adversaries may attempt to get a listing of domain accounts. This information can help adversaries determine which domain accounts exist to aid in follow-on behavior such as targeting specific accounts which possess particular privileges.

Commands such as `net user /domain` and `net group /domain` of the [Net](#) utility, `dscacheutil -q group` on macOS, and `ldapsearch` on Linux can list domain users and groups. [PowerShell](#) cmdlets including `Get-ADUser` and `Get-ADGroupMember` may enumerate members of Active Directory groups. (Citation: CrowdStrike StellarParticle January 2022)

## System Network Configuration Discovery - T1016

Adversaries may look for details about the network configuration and settings, such as IP and/or MAC addresses, of systems they access or through information discovery of remote systems. Several operating system administration utilities exist that can be used to gather this information. Examples include [Arp](#), [ipconfig/ifconfig](#), [nbtstat](#), and [route](#).

Adversaries may also leverage a [Network Device CLI](#) on network devices to gather information about configurations and settings, such as IP addresses of configured interfaces and static/dynamic routes (e.g. `show ip route`, `show ip interface`). (Citation: US-CERT-TA18-106A) (Citation: Mandiant APT41 Global Intrusion ) On ESXi, adversaries may leverage `esxcli` to gather network configuration information. For example, the command `esxcli network nic list` will retrieve the MAC address, while `esxcli network ip interface ipv4 get` will retrieve the local IPv4 address. (Citation: Trellix Rnasomhouse 2024)

Adversaries may use the information from [System Network Configuration Discovery](#) during automated discovery to shape follow-on behaviors, including determining certain access within the target network and what actions to do next.

## Clear Windows Event Logs - T1070.001

Adversaries may clear Windows Event Logs to hide the activity of an intrusion. Windows Event Logs are a record of a computer's alerts and notifications. There are three system-defined sources of events: System, Application, and Security, with five event types: Error, Warning, Information, Success Audit, and Failure Audit.

With administrator privileges, the event logs can be cleared with the following utility commands:

- `wevtutil cl system`
- `wevtutil cl application`
- `wevtutil cl security`



These logs may also be cleared through other mechanisms, such as the event viewer GUI or [PowerShell](#). For example, adversaries may use the PowerShell command `Remove-EventLog -LogName Security` to delete the Security EventLog and after reboot, disable future logging. Note: events may still be generated and logged in the .evtx file between the time the command is run and the reboot.(Citation: disable\_win\_evt\_logging)

Adversaries may also attempt to clear logs by directly deleting the stored log files within `C:\Windows\System32\winevt\logs\`.

### Remote System Discovery - T1018

Adversaries may attempt to get a listing of other systems by IP address, hostname, or other logical identifier on a network that may be used for Lateral Movement from the current system. Functionality could exist within remote access tools to enable this, but utilities available on the operating system could also be used such as [Ping](#), `net view` using [Net](#), or, on ESXi servers, `esxcli network diag ping`.

Adversaries may also analyze data from local host files (ex: `C:\Windows\System32\Drivers\etc\hosts` or `/etc/hosts`) or other passive means (such as local [Arp](#) cache entries) in order to discover the presence of remote systems in an environment.

Adversaries may also target discovery of network infrastructure as well as leverage [Network Device CLI](#) commands on network devices to gather detailed information about systems within a network (e.g. `show cdp neighbors`, `show arp`).(Citation: US-CERT-TA18-106A)(Citation: CISA AR21-126A FIVEHANDS May 2021)

### Valid Accounts - T1078

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent access to remote systems and externally available services, such as VPNs, Outlook Web Access, network devices, and remote desktop.(Citation: volexity\_0day\_sophos\_FW) Compromised credentials may also grant an adversary increased privilege to specific systems or access to restricted areas of the network. Adversaries may choose not to use malware or tools in conjunction with the legitimate access those credentials provide to make it harder to detect their presence.

In some cases, adversaries may abuse inactive accounts: for example, those belonging to individuals who are no longer part of an organization. Using these accounts may allow the adversary to evade detection, as the original account user will not be present to identify any anomalous activity taking place on their account. (Citation: CISA MFA PrintNightmare)

The overlap of permissions for local, domain, and cloud accounts across a network of systems is of concern because the adversary may be able to pivot across accounts and systems to reach a high level of access (i.e., domain or enterprise administrator) to bypass access controls set within the enterprise.(Citation: TechNet Credential Theft)

### OS Credential Dumping - T1003

Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password. Credentials can be obtained from OS caches, memory, or structures.

(Citation: Brining MimiKatz to Unix) Credentials can then be used to perform [Lateral Movement](#) and access restricted information.

Several of the tools mentioned in associated sub-techniques may be used by both adversaries and professional security testers. Additional custom tools likely exist as well.

### **Process Discovery - T1057**

Adversaries may attempt to get information about running processes on a system. Information obtained could be used to gain an understanding of common software/applications running on systems within the network. Administrator or otherwise elevated access may provide better process details. Adversaries may use the information from [Process Discovery](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

In Windows environments, adversaries could obtain details on running processes using the [Tasklist](#) utility via [cmd](#) or [Get-Process](#) via [PowerShell](#). Information about processes can also be extracted from the output of [Native API](#) calls such as [CreateToolhelp32Snapshot](#). In Mac and Linux, this is accomplished with the [ps](#) command. Adversaries may also opt to enumerate processes via [/proc](#). ESXi also supports use of the [ps](#) command, as well as [esxcli system process list](#).(Citation: Sygnia ESXi Ransomware 2025)(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)

On network devices, [Network Device CLI](#) commands such as [show processes](#) can be used to display current running processes.(Citation: US-CERT-TA18-106A)(Citation: show\_processes\_cisco\_cmd)

### **Web Service - T1102**

Adversaries may use an existing, legitimate external Web service as a means for relaying data to/from a compromised system. Popular websites, cloud services, and social media acting as a mechanism for C2 may give a significant amount of cover due to the likelihood that hosts within a network are already communicating with them prior to a compromise. Using common services, such as those offered by Google, Microsoft, or Twitter, makes it easier for adversaries to hide in expected noise.(Citation: Broadcom BirdyClient Microsoft Graph API 2024) Web service providers commonly use SSL/TLS encryption, giving adversaries an added level of protection.

Use of Web services may also protect back-end C2 infrastructure from discovery through malware binary analysis while also enabling operational resiliency (since this infrastructure may be dynamically changed).

### **Obfuscated Files or Information - T1027**

Adversaries may attempt to make an executable or file difficult to discover or analyze by encrypting, encoding, or otherwise obfuscating its contents on the system or in transit. This is common behavior that can be used across different platforms and the network to evade defenses.

Payloads may be compressed, archived, or encrypted in order to avoid detection. These payloads may be used during Initial Access or later to mitigate detection. Sometimes a user's action may be required to open and [Deobfuscate/Decode Files or Information](#) for [User Execution](#). The user may also be required to input a password to open a password protected compressed/encrypted file that was provided by the adversary. (Citation: Volatility PowerDuke November 2016) Adversaries may also use compressed or archived scripts, such as JavaScript.

Portions of files can also be encoded to hide the plain-text strings that would otherwise help defenders with discovery. (Citation: Linux/Cdorked.A We Live Security Analysis) Payloads may also be split into separate, seemingly benign files that only reveal malicious functionality when reassembled. (Citation: Carbon Black Obfuscation Sept 2016)

Adversaries may also abuse [Command Obfuscation](#) to obscure commands executed from payloads or directly via [Command and Scripting Interpreter](#). Environment variables, aliases, characters, and other platform/language specific semantics can be used to evade signature based detections and application control mechanisms. (Citation: FireEye Obfuscation June 2017) (Citation: FireEye Revoke-Obfuscation July 2017)(Citation: PaloAlto EncodedCommand March 2017)

### **Service Execution - T1569.002**

Adversaries may abuse the Windows service control manager to execute malicious commands or payloads. The Windows service control manager ([services.exe](#)) is an interface to manage and manipulate services. (Citation: Microsoft Service Control Manager) The service control manager is accessible to users via GUI components as well as system utilities such as [sc.exe](#) and [Net](#).

[PsExec](#) can also be used to execute commands or payloads via a temporary Windows service created through the service control manager API.(Citation: Russinovich Sysinternals) Tools such as [PsExec](#) and [sc.exe](#) can accept remote servers as arguments and may be used to conduct remote execution.

Adversaries may leverage these mechanisms to execute malicious content. This can be done by either executing a new or modified service. This technique is the execution used in conjunction with [Windows Service](#) during service persistence or privilege escalation.

### **Indicator Removal - T1070**

Adversaries may delete or modify artifacts generated within systems to remove evidence of their presence or hinder defenses. Various artifacts may be created by an adversary or something that can be attributed to an adversary's actions. Typically these artifacts are used as defensive indicators related to monitored events, such as strings from downloaded files, logs that are generated from user actions, and other data analyzed by defenders. Location, format, and type of artifact (such as command or login history) are often specific to each platform.

Removal of these indicators may interfere with event collection, reporting, or other processes used to detect intrusion activity. This may compromise the integrity of security solutions by causing notable events to go unreported. This activity may also impede forensic analysis and incident response, due to lack of sufficient data to determine what occurred.

### **Valid Accounts - T1078**

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent access to remote systems and externally available services, such as VPNs, Outlook Web Access, network devices, and remote desktop.(Citation: volexity\_0day\_sophos\_FW) Compromised credentials may also grant an adversary increased privilege to specific systems or access to restricted areas of the network. Adversaries may

choose not to use malware or tools in conjunction with the legitimate access those credentials provide to make it harder to detect their presence.

In some cases, adversaries may abuse inactive accounts: for example, those belonging to individuals who are no longer part of an organization. Using these accounts may allow the adversary to evade detection, as the original account user will not be present to identify any anomalous activity taking place on their account. (Citation: CISA MFA PrintNightmare)

The overlap of permissions for local, domain, and cloud accounts across a network of systems is of concern because the adversary may be able to pivot across accounts and systems to reach a high level of access (i.e., domain or enterprise administrator) to bypass access controls set within the enterprise. (Citation: TechNet Credential Theft)

### **Virtualization/Sandbox Evasion - T1497**

Adversaries may employ various means to detect and avoid virtualization and analysis environments. This may include changing behaviors based on the results of checks for the presence of artifacts indicative of a virtual machine environment (VME) or sandbox. If the adversary detects a VME, they may alter their malware to disengage from the victim or conceal the core functions of the implant. They may also search for VME artifacts before dropping secondary or additional payloads. Adversaries may use the information learned from [Virtualization/Sandbox Evasion](#) during automated discovery to shape follow-on behaviors. (Citation: Deloitte Environment Awareness)

Adversaries may use several methods to accomplish [Virtualization/Sandbox Evasion](#) such as checking for security monitoring tools (e.g., Sysinternals, Wireshark, etc.) or other system artifacts associated with analysis or virtualization. Adversaries may also check for legitimate user activity to help determine if it is in an analysis environment. Additional methods include use of sleep timers or loops within malware code to avoid operating within a temporary sandbox. (Citation: Unit 42 Pirpi July 2015)

### **Python - T1059.006**

Adversaries may abuse Python commands and scripts for execution. Python is a very popular scripting/programming language, with capabilities to perform many functions. Python can be executed interactively from the command-line (via the `python.exe` interpreter) or via scripts (.py) that can be written and distributed to different systems. Python code can also be compiled into binary executables. (Citation: Zscaler APT31 Covid-19 October 2020)

Python comes with many built-in packages to interact with the underlying system, such as file operations and device I/O. Adversaries can use these libraries to download and execute commands or other scripts as well as perform various malicious behaviors.

### **Local Accounts - T1078.003**

Adversaries may obtain and abuse credentials of a local account as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Local accounts are those configured by an organization for use by users, remote support, services, or for administration on a single system or service.

Local Accounts may also be abused to elevate privileges and harvest credentials through [OS Credential Dumping](#). Password reuse may allow the abuse of local accounts across a set of machines on a network for

the purposes of Privilege Escalation and Lateral Movement.

### Local Account - T1087.001

Adversaries may attempt to get a listing of local system accounts. This information can help adversaries determine which local accounts exist on a system to aid in follow-on behavior.

Commands such as `net user` and `net localgroup` of the `Net` utility and `id` and `groups` on macOS and Linux can list local users and groups.(Citation: Mandiant APT1)(Citation: id man page)(Citation: groups man page) On Linux, local users can also be enumerated through the use of the `/etc/passwd` file. On macOS, the `dscl . list /Users` command can be used to enumerate local accounts. On ESXi servers, the `esxcli system account list` command can list local user accounts.(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)

### Account Discovery - T1087

Adversaries may attempt to get a listing of valid accounts, usernames, or email addresses on a system or within a compromised environment. This information can help adversaries determine which accounts exist, which can aid in follow-on behavior such as brute-forcing, spear-phishing attacks, or account takeovers (e.g., [Valid Accounts](#)).

Adversaries may use several methods to enumerate accounts, including abuse of existing tools, built-in commands, and potential misconfigurations that leak account names and roles or permissions in the targeted environment.

For examples, cloud environments typically provide easily accessible interfaces to obtain user lists.(Citation: AWS List Users)(Citation: Google Cloud - IAM Service Accounts List API) On hosts, adversaries can use default [PowerShell](#) and other command line functionality to identify accounts. Information about email addresses and accounts may also be extracted by searching an infected system's files.

### SSH - T1021.004

Adversaries may use [Valid Accounts](#) to log into remote machines using Secure Shell (SSH). The adversary may then perform actions as the logged-on user.

SSH is a protocol that allows authorized users to open remote shells on other computers. Many Linux and macOS versions come with SSH installed by default, although typically disabled until the user enables it. On ESXi, SSH can be enabled either directly on the host (e.g., via `vim-cmd hostsvc/enable_ssh`) or via vCenter.(Citation: Sygnia ESXi Ransomware 2025)(Citation: TrendMicro ESXi Ransomware)(Citation: Sygnia Abyss Locker 2025) The SSH server can be configured to use standard password authentication or public-private keypairs in lieu of or in addition to a password. In this authentication scenario, the user's public key must be in a special file on the computer running the server that lists which keypairs are allowed to login as that user (i.e., [SSH Authorized Keys](#)).

### System Owner/User Discovery - T1033

Adversaries may attempt to identify the primary user, currently logged in user, set of users that commonly uses a system, or whether a user is actively using the system. They may do this, for example, by retrieving account usernames or by using [OS Credential Dumping](#). The information may be collected in a number of

different ways using other Discovery techniques, because user and username details are prevalent throughout a system and include running process ownership, file/directory ownership, session information, and system logs. Adversaries may use the information from [System Owner/User Discovery](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

Various utilities and commands may acquire this information, including `whoami`. In macOS and Linux, the currently logged in user can be identified with `w` and `who`. On macOS the `dscl . list /Users | grep -v '_'` command can also be used to enumerate user accounts. Environment variables, such as `%USERNAME%` and `$USER`, may also be used to access this information.

On network devices, [Network Device CLI](#) commands such as `show users` and `show ssh` can be used to display users currently logged into the device.(Citation: `show_ssh_users_cmd_cisco`)(Citation: US-CERT TA18-106A Network Infrastructure Devices 2018)

## Impair Defenses - T1562

Adversaries may maliciously modify components of a victim environment in order to hinder or disable defensive mechanisms. This not only involves impairing preventative defenses, such as firewalls and anti-virus, but also detection capabilities that defenders can use to audit activity and identify malicious behavior. This may also span both native defenses as well as supplemental capabilities installed by users and administrators.

Adversaries may also impair routine operations that contribute to defensive hygiene, such as blocking users from logging out, preventing a system from shutting down, or disabling or modifying the update process. Adversaries could also target event aggregation and analysis mechanisms, or otherwise disrupt these procedures by altering other system components. These restrictions can further enable malicious operations as well as the continued propagation of incidents.(Citation: Google Cloud Mandiant UNC3886 2024)(Citation: Emotet shutdown)

## Ingress Tool Transfer - T1105

Adversaries may transfer tools or other files from an external system into a compromised environment. Tools or files may be copied from an external adversary-controlled system to the victim network through the command and control channel or through alternate protocols such as `ftp`. Once present, adversaries may also transfer/spread tools between victim devices within a compromised environment (i.e. [Lateral Tool Transfer](#)).

On Windows, adversaries may use various utilities to download tools, such as `copy`, `finger`, `certutil`, and `PowerShell` commands such as `IEX(New-Object Net.WebClient).downloadString()` and `Invoke-WebRequest`. On Linux and macOS systems, a variety of utilities also exist, such as `curl`, `scp`, `sftp`, `tftp`, `rsync`, `finger`, and `wget`.(Citation: `t1105_lolbas`) A number of these tools, such as `wget`, `curl`, and `scp`, also exist on ESXi. After downloading a file, a threat actor may attempt to verify its integrity by checking its hash value (e.g., via `certutil -hashfile`). (Citation: Google Cloud Threat Intelligence COSMICENERGY 2023)

Adversaries may also abuse installers and package managers, such as `yum` or `winget`, to download tools to victim hosts. Adversaries have also abused file application features, such as the Windows `search-ms` protocol handler, to deliver malicious files to victims through remote file searches invoked by [User Execution](#) (typically after interacting with [Phishing](#) lures).(Citation: T1105: Trellix\_search-ms)



Files can also be transferred using various [Web Services](#) as well as native or otherwise present tools on the victim system.(Citation: PTSecurity Cobalt Dec 2016) In some cases, adversaries may be able to leverage services that sync between a web-based and an on-premises client, such as Dropbox or OneDrive, to transfer files onto victim systems. For example, by compromising a cloud account and logging into the service's web portal, an adversary may be able to trigger an automatic syncing process that transfers the file onto the victim's machine.(Citation: Dropbox Malware Sync)

### **Exploit Public-Facing Application - T1190**

Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.

Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets.(Citation: NVD CVE-2016-6662)(Citation: CIS Multiple SMB Vulnerabilities)(Citation: US-CERT TA18-106A Network Infrastructure Devices 2018)(Citation: Cisco Blog Legacy Device Attacks)(Citation: NVD CVE-2014-7169) On ESXi infrastructure, adversaries may exploit exposed OpenSLP services; they may alternatively exploit exposed VMware vCenter servers.(Citation: Recorded Future ESXiArgs Ransomware 2023)(Citation: Ars Technica VMWare Code Execution Vulnerability 2021) Depending on the flaw being exploited, this may also involve [Exploitation for Defense Evasion](#) or [Exploitation for Client Execution](#).

If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs (e.g., via the [Cloud Instance Metadata API](#)), exploit container host access via [Escape to Host](#), or take advantage of weak identity and access management policies.

Adversaries may also exploit edge network infrastructure and related appliances, specifically targeting devices that do not support robust host-based defenses.(Citation: Mandiant Fortinet Zero Day)(Citation: Wired Russia Cyberwar)

For websites and databases, the OWASP top 10 and CWE top 25 highlight the most common web-based vulnerabilities.(Citation: OWASP Top 10)(Citation: CWE top 25)

### **System Information Discovery - T1082**

An adversary may attempt to get detailed information about the operating system and hardware, including version, patches, hotfixes, service packs, and architecture. Adversaries may use this information to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions. This behavior is distinct from [Local Storage Discovery](#) which is an adversary's discovery of local drive, disks and/or volumes.

Tools such as [Systeminfo](#) can be used to gather detailed system information. If running with privileged access, a breakdown of system data can be gathered through the [systemsetup](#) configuration tool on macOS. Adversaries may leverage a [Network Device CLI](#) on network devices to gather detailed system information (e.g. [show version](#)).(Citation: US-CERT-TA18-106A) On ESXi servers, threat actors may gather system information from various esxcli utilities, such as [system hostname get](#) and [system version get](#).(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)(Citation: Varonis)



Infrastructure as a Service (IaaS) cloud providers such as AWS, GCP, and Azure allow access to instance and virtual machine information via APIs. Successful authenticated API calls can return data such as the operating system platform and status of a particular instance or the model view of a virtual machine.(Citation: Amazon Describe Instance)(Citation: Google Instances Resource)(Citation: Microsoft Virtual Machine API)

[System Information Discovery](#) combined with information gathered from other forms of discovery and reconnaissance can drive payload development and concealment.(Citation: OSX.FairyTale)(Citation: 20 macOS Common Tools and Techniques)

### **Remote Services - T1021**

Adversaries may use [Valid Accounts](#) to log into a service that accepts remote connections, such as telnet, SSH, and VNC. The adversary may then perform actions as the logged-on user.

In an enterprise environment, servers and workstations can be organized into domains. Domains provide centralized identity management, allowing users to login using one set of credentials across the entire network. If an adversary is able to obtain a set of valid domain credentials, they could login to many different machines using remote access protocols such as secure shell (SSH) or remote desktop protocol (RDP). (Citation: SSH Secure Shell)(Citation: TechNet Remote Desktop Services) They could also login to accessible SaaS or IaaS services, such as those that federate their identities to the domain, or management platforms for internal virtualization environments such as VMware vCenter.

Legitimate applications (such as [Software Deployment Tools](#) and other administrative programs) may utilize [Remote Services](#) to access remote hosts. For example, Apple Remote Desktop (ARD) on macOS is native software used for remote management. ARD leverages a blend of protocols, including [VNC](#) to send the screen and control buffers and [SSH](#) for secure file transfer.(Citation: Remote Management MDM macOS)(Citation: Kickstart Apple Remote Desktop commands)(Citation: Apple Remote Desktop Admin Guide 3.3) Adversaries can abuse applications such as ARD to gain remote code execution and perform lateral movement. In versions of macOS prior to 10.14, an adversary can escalate an SSH session to an ARD session which enables an adversary to accept TCC (Transparency, Consent, and Control) prompts without user interaction and gain access to data.(Citation: FireEye 2019 Apple Remote Desktop)(Citation: Lockboxx ARD 2019)(Citation: Kickstart Apple Remote Desktop commands)

### **Archive Collected Data - T1560**

An adversary may compress and/or encrypt data that is collected prior to exfiltration. Compressing the data can help to obfuscate the collected data and minimize the amount of data sent over the network.(Citation: DOJ GRU Indictment Jul 2018) Encryption can be used to hide information that is being exfiltrated from detection or make exfiltration less conspicuous upon inspection by a defender.

Both compression and encryption are done prior to exfiltration, and can be performed using a utility, 3rd party library, or custom method.

### **Impair Defenses - T1562**

Adversaries may maliciously modify components of a victim environment in order to hinder or disable defensive mechanisms. This not only involves impairing preventative defenses, such as firewalls and anti-virus, but also detection capabilities that defenders can use to audit activity and identify malicious behavior. This may also span both native defenses as well as supplemental capabilities installed by users and administrators.

Adversaries may also impair routine operations that contribute to defensive hygiene, such as blocking users from logging out, preventing a system from shutting down, or disabling or modifying the update process. Adversaries could also target event aggregation and analysis mechanisms, or otherwise disrupt these procedures by altering other system components. These restrictions can further enable malicious operations as well as the continued propagation of incidents.(Citation: Google Cloud Mandiant UNC3886 2024)(Citation: Emotet shutdown)

### **Obfuscated Files or Information - T1027**

Adversaries may attempt to make an executable or file difficult to discover or analyze by encrypting, encoding, or otherwise obfuscating its contents on the system or in transit. This is common behavior that can be used across different platforms and the network to evade defenses.

Payloads may be compressed, archived, or encrypted in order to avoid detection. These payloads may be used during Initial Access or later to mitigate detection. Sometimes a user's action may be required to open and [Deobfuscate/Decode Files or Information](#) for [User Execution](#). The user may also be required to input a password to open a password protected compressed/encrypted file that was provided by the adversary. (Citation: Volexity PowerDuke November 2016) Adversaries may also use compressed or archived scripts, such as JavaScript.

Portions of files can also be encoded to hide the plain-text strings that would otherwise help defenders with discovery. (Citation: Linux/Cdorked.A We Live Security Analysis) Payloads may also be split into separate, seemingly benign files that only reveal malicious functionality when reassembled. (Citation: Carbon Black Obfuscation Sept 2016)

Adversaries may also abuse [Command Obfuscation](#) to obscure commands executed from payloads or directly via [Command and Scripting Interpreter](#). Environment variables, aliases, characters, and other platform/language specific semantics can be used to evade signature based detections and application control mechanisms. (Citation: FireEye Obfuscation June 2017) (Citation: FireEye Revoke-Obfuscation July 2017)(Citation: PaloAlto EncodedCommand March 2017)

### **External Remote Services - T1133**

Adversaries may leverage external-facing remote services to initially access and/or persist within a network. Remote services such as VPNs, Citrix, and other access mechanisms allow users to connect to internal enterprise network resources from external locations. There are often remote service gateways that manage connections and credential authentication for these services. Services such as [Windows Remote Management](#) and [VNC](#) can also be used externally.(Citation: MacOS VNC software for Remote Desktop)

Access to [Valid Accounts](#) to use the service is often a requirement, which could be obtained through credential pharming or by obtaining the credentials from users after compromising the enterprise network. (Citation: Volexity Virtual Private Keylogging) Access to remote services may be used as a redundant or persistent access mechanism during an operation.

Access may also be gained through an exposed service that doesn't require authentication. In containerized environments, this may include an exposed Docker API, Kubernetes API server, kubelet, or web application such as the Kubernetes dashboard.(Citation: Trend Micro Exposed Docker Server)(Citation: Unit 42 Hildegard Malware)

Adversaries may also establish persistence on network by configuring a Tor hidden service on a compromised system. Adversaries may utilize the tool [ShadowLink](#) to facilitate the installation and configuration of the Tor hidden service. Tor hidden service is then accessible via the Tor network because [ShadowLink](#) sets up a .onion address on the compromised system. [ShadowLink](#) may be used to forward any inbound connections to RDP, allowing the adversaries to have remote access.(Citation: The BadPilot campaign) Adversaries may get [ShadowLink](#) to persist on a system by masquerading it as an MS Defender application.(Citation: Russian threat actors dig in, prepare to seize on war fatigue)

### **File Deletion - T1070.004**

Adversaries may delete files left behind by the actions of their intrusion activity. Malware, tools, or other non-native files dropped or created on a system by an adversary (ex: [Ingress Tool Transfer](#)) may leave traces to indicate to what was done within a network and how. Removal of these files can occur during an intrusion, or as part of a post-intrusion process to minimize the adversary's footprint.

There are tools available from the host operating system to perform cleanup, but adversaries may use other tools as well.(Citation: Microsoft SDelete July 2016) Examples of built-in [Command and Scripting Interpreter](#) functions include [del](#) on Windows, [rm](#) or [unlink](#) on Linux and macOS, and [rm](#) on ESXi.

### **Encrypted Channel - T1573**

Adversaries may employ an encryption algorithm to conceal command and control traffic rather than relying on any inherent protections provided by a communication protocol. Despite the use of a secure algorithm, these implementations may be vulnerable to reverse engineering if secret keys are encoded and/or generated within malware samples/configuration files.

### **Lateral Tool Transfer - T1570**

Adversaries may transfer tools or other files between systems in a compromised environment. Once brought into the victim environment (i.e., [Ingress Tool Transfer](#)) files may then be copied from one system to another to stage adversary tools or other files over the course of an operation.

Adversaries may copy files between internal victim systems to support lateral movement using inherent file sharing protocols such as file sharing over [SMB/Windows Admin Shares](#) to connected network shares or with authenticated connections via [Remote Desktop Protocol](#).(Citation: Unit42 LockerGoga 2019)

Files can also be transferred using native or otherwise present tools on the victim system, such as scp, rsync, curl, sftp, and [ftp](#). In some cases, adversaries may be able to leverage [Web Services](#) such as Dropbox or OneDrive to copy files from one machine to another via shared, automatically synced folders.(Citation: Dropbox Malware Sync)

### **Internal Defacement - T1491.001**

An adversary may deface systems internal to an organization in an attempt to intimidate or mislead users, thus discrediting the integrity of the systems. This may take the form of modifications to internal websites or server login messages, or directly to user systems with the replacement of the desktop wallpaper.(Citation: Novetta Blockbuster)(Citation: Varonis) Disturbing or offensive images may be used as a part of [Internal Defacement](#) in order to cause user discomfort, or to pressure compliance with accompanying messages. Since

internally defacing systems exposes an adversary's presence, it often takes place after other intrusion goals have been accomplished.(Citation: Novetta Blockbuster Destructive Malware)

### **Service Stop - T1489**

Adversaries may stop or disable services on a system to render those services unavailable to legitimate users. Stopping critical services or processes can inhibit or stop response to an incident or aid in the adversary's overall objectives to cause damage to the environment.(Citation: Talos Olympic Destroyer 2018)(Citation: Novetta Blockbuster)

Adversaries may accomplish this by disabling individual services of high importance to an organization, such as [MSEExchangeIS](#), which will make Exchange content inaccessible.(Citation: Novetta Blockbuster) In some cases, adversaries may stop or disable many or all services to render systems unusable.(Citation: Talos Olympic Destroyer 2018) Services or processes may not allow for modification of their data stores while running. Adversaries may stop services or processes in order to conduct [Data Destruction](#) or [Data Encrypted for Impact](#) on the data stores of services like Exchange and SQL Server, or on virtual machines hosted on ESXi infrastructure.(Citation: SecureWorks WannaCry Analysis)(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)

Threat actors may also disable or stop service in cloud environments. For example, by leveraging the [DisableAPIServiceAccess](#) API in AWS, a threat actor may prevent the service from creating service-linked roles on new accounts in the AWS Organization.(Citation: Datadog Security Labs Cloud Persistence 2025) (Citation: AWS DisableAWSServiceAccess)

### **Tool - T1588.002**

Adversaries may buy, steal, or download software tools that can be used during targeting. Tools can be open or closed source, free or commercial. A tool can be used for malicious purposes by an adversary, but (unlike malware) were not intended to be used for those purposes (ex: [PsExec](#)).

Adversaries may obtain tools to support their operations, including to support execution of post-compromise behaviors. Tools may also be leveraged for testing – for example, evaluating malware against commercial antivirus or endpoint detection and response (EDR) applications.(Citation: Forescout Conti Leaks 2022) (Citation: Sentinel Labs Top Tier Target 2025)

Tool acquisition may involve the procurement of commercial software licenses, including for red teaming tools such as Cobalt Strike. In addition to freely downloading or purchasing software, adversaries may steal software and/or software licenses from third-party entities (including other adversaries). Threat actors may also crack trial versions of software.(Citation: Recorded Future Beacon 2019)

### **Proxy - T1090**

Adversaries may use a connection proxy to direct network traffic between systems or act as an intermediary for network communications to a command and control server to avoid direct connections to their infrastructure. Many tools exist that enable traffic redirection through proxies or port redirection, including [HTRAN](#), ZXProxy, and ZXPortMap. (Citation: Trend Micro APT Attack Tools) Adversaries use these types of proxies to manage command and control communications, reduce the number of simultaneous outbound network connections, provide resiliency in the face of connection loss, or to ride over existing trusted

communications paths between victims to avoid suspicion. Adversaries may chain together multiple proxies to further disguise the source of malicious traffic.

Adversaries can also take advantage of routing schemes in Content Delivery Networks (CDNs) to proxy command and control traffic.

### **File and Directory Discovery - T1083**

Adversaries may enumerate files and directories or may search in specific locations of a host or network share for certain information within a file system. Adversaries may use the information from [File and Directory Discovery](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

Many command shell utilities can be used to obtain this information. Examples include `dir`, `tree`, `ls`, `find`, and `locate`.(Citation: Windows Commands JPCERT) Custom tools may also be used to gather file and directory information and interact with the [Native API](#). Adversaries may also leverage a [Network Device CLI](#) on network devices to gather file and directory information (e.g. `dir`, `show flash`, and/or `nvr`).(Citation: US-CERT-TA18-106A)

Some files and directories may require elevated or specific user permissions to access.